

Engagement Types & Rules of Engagement

Test models

Model	Knowledge given	Realism of attacker
Black-box	Nothing (or fake account)	External attacker / zero-day researcher
Gray-box	Credentials, architecture summary	Insider-ish, realistic post-authenticated risk
White-box	Full source, config, infra docs	Audits, DevSecOps, "assume knowledge"

Budget and goals drive choice: black-box is realistic but expensive; white-box finds the deepest logic flaws fast.

Rules of Engagement (RoE) – the legal scope

Everything you may test, defined in writing:

- Authorized target range/organization (IP scope, domains, hosts)

- Testing window (start/stop, blackout times)

- Allowed techniques (or **prohibited**: DoS severities, social engineering, exfiltration, destructive actions)

- Emergency contacts + stop-work trigger

- Data handling (no copying beyond need, no personal data)

- Lines of communication and reporting cadence

Scope boundaries worth negotiating

- Third-party systems (a SaaS you use) – often out of scope, requires their vendor authorization

Production vs staging – prefer staging for dangerous tests
Cloud provider basins (AWS/DB) – respect provider terms
Sensitive systems (HR, billing) – flag "careful handling" rather than forbid

Getting it in writing

A professional test ONLY with a signed RoE/SOW/authorization letter.
Verbally "about it" is not authorization. When in doubt: stop and ask in writing.

Memorize the question: "Who authorized this, in writing, and what exactly did they authorize?" If you cannot answer with documents, you are not testing – you are committing a crime.

[← Module start](#)

[The Penetration Testing Lifecycle...](#)